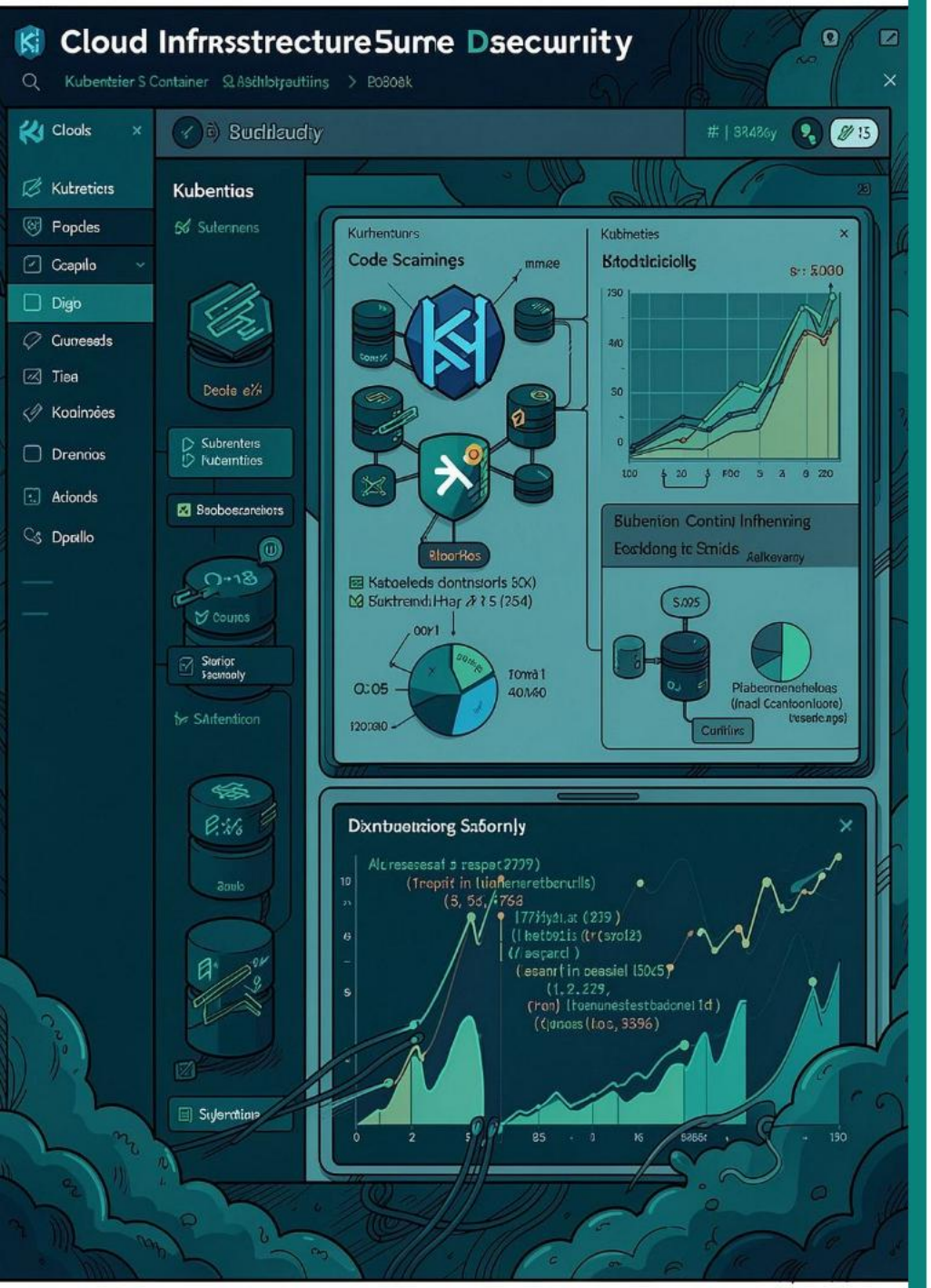


Benchmarking Cloud-Native Misconfiguration Scanners

A controlled comparison of Checkov, Trivy and Kubescape

Honours research presentation
University of Johannesburg

Why scanner results are difficult to compare

The same artifact can produce incompatible evidence

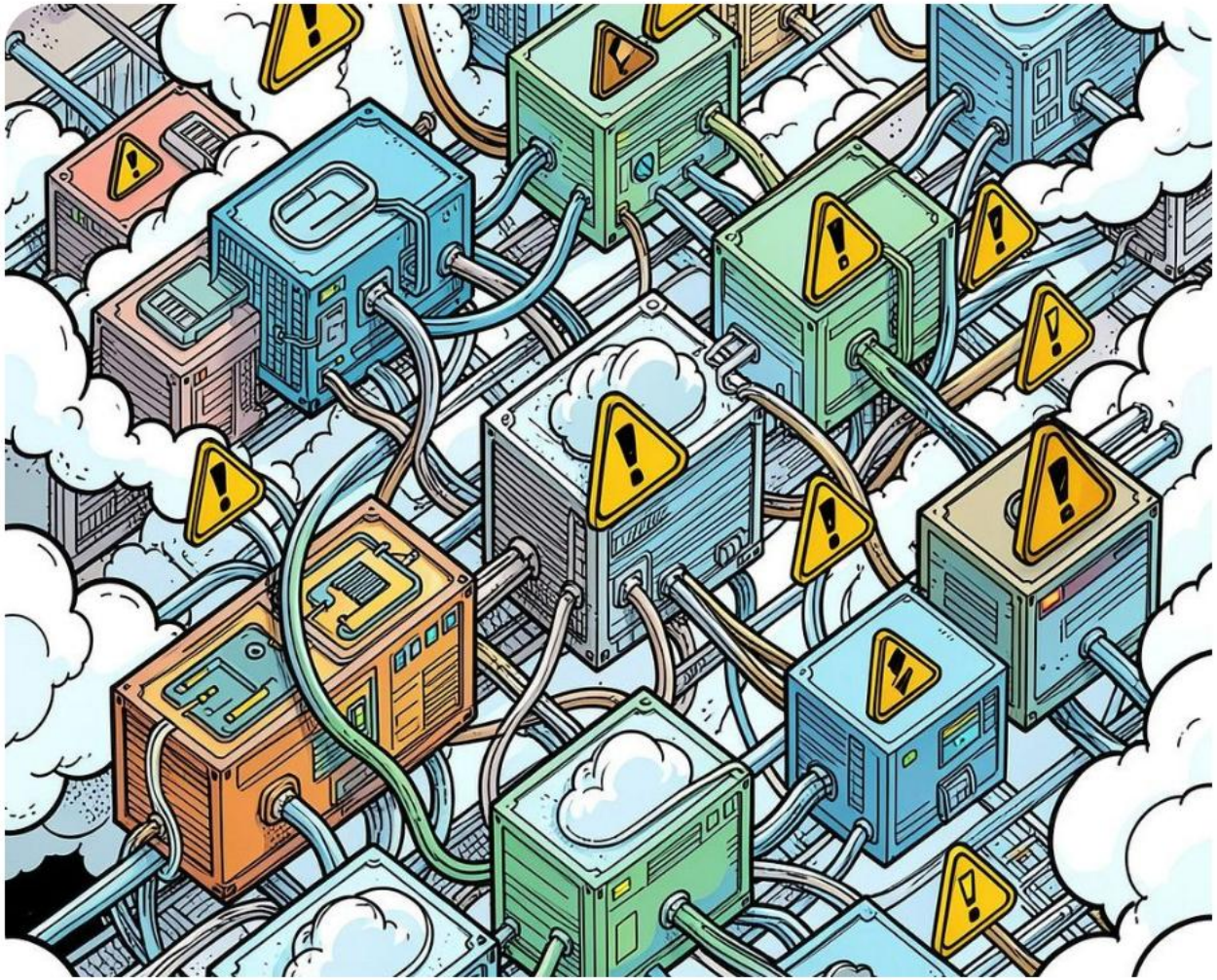
Different rule IDs

Equivalent findings use scanner-specific names, so matching by identifier alone fails.

Different JSON structures

Raw alert totals do not prove that a scanner found the issue that the case was built to test.

A fair comparison needs labelled ground truth and one common evaluation method.



Controlled benchmark design

Ground truth is defined before scanner performance is evaluated

60

deliberately insecure use cases

160

applicable scanner-case results

3

artifact families

20 Kubernetes YAML

Checkov · Trivy · Kubescape

20 Dockerfiles

20 Helm charts

Kubescape is not applicable to Dockerfiles

Evaluation pipeline

Every scanner follows the same traceable path



Strict matching treats findings without a ground-truth mapping as false positives for that controlled case.

Live prototype

A complete user journey from one labelled case to the corpus-wide comparison

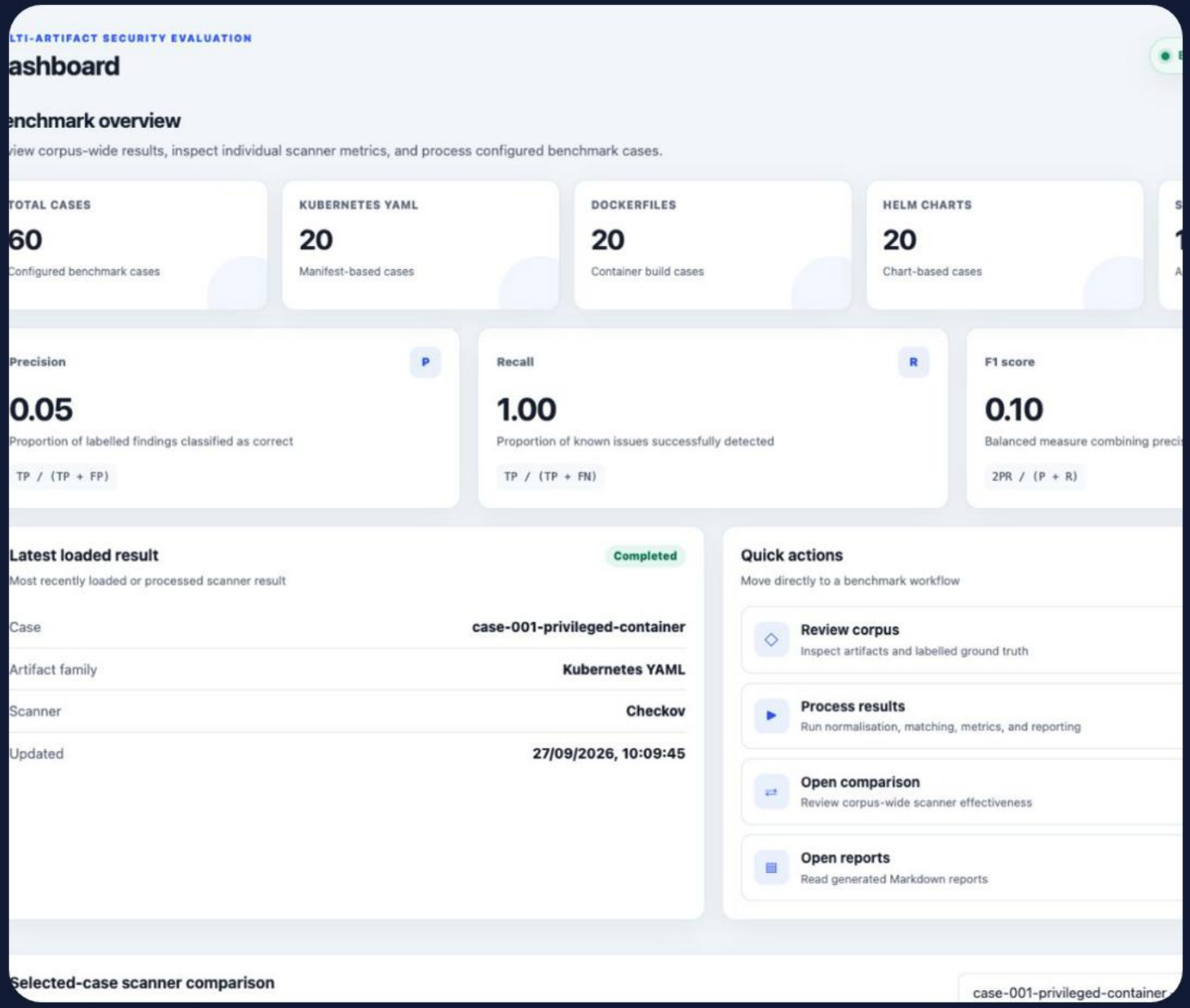
Corpus

Process

Inspect outputs

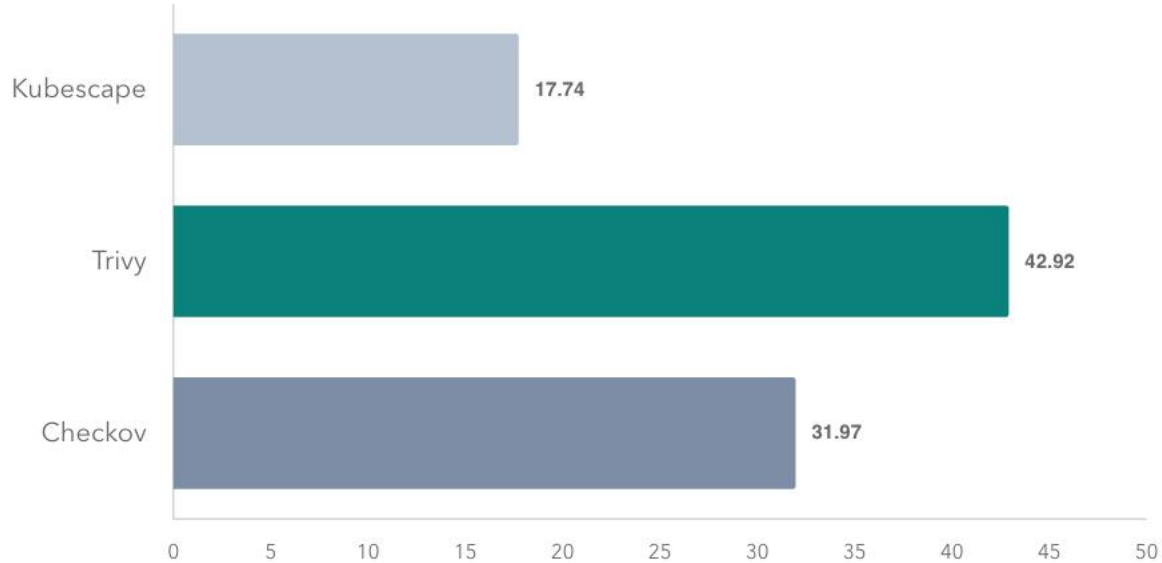
Compare

The demonstration follows case-001-privileged-container across all three scanners.



Major findings

Results from this controlled corpus



Trivy has the strongest overall balance

Dockerfiles produce the highest family scores. Helm produces the lowest because additional unmapped findings reduce precision.

